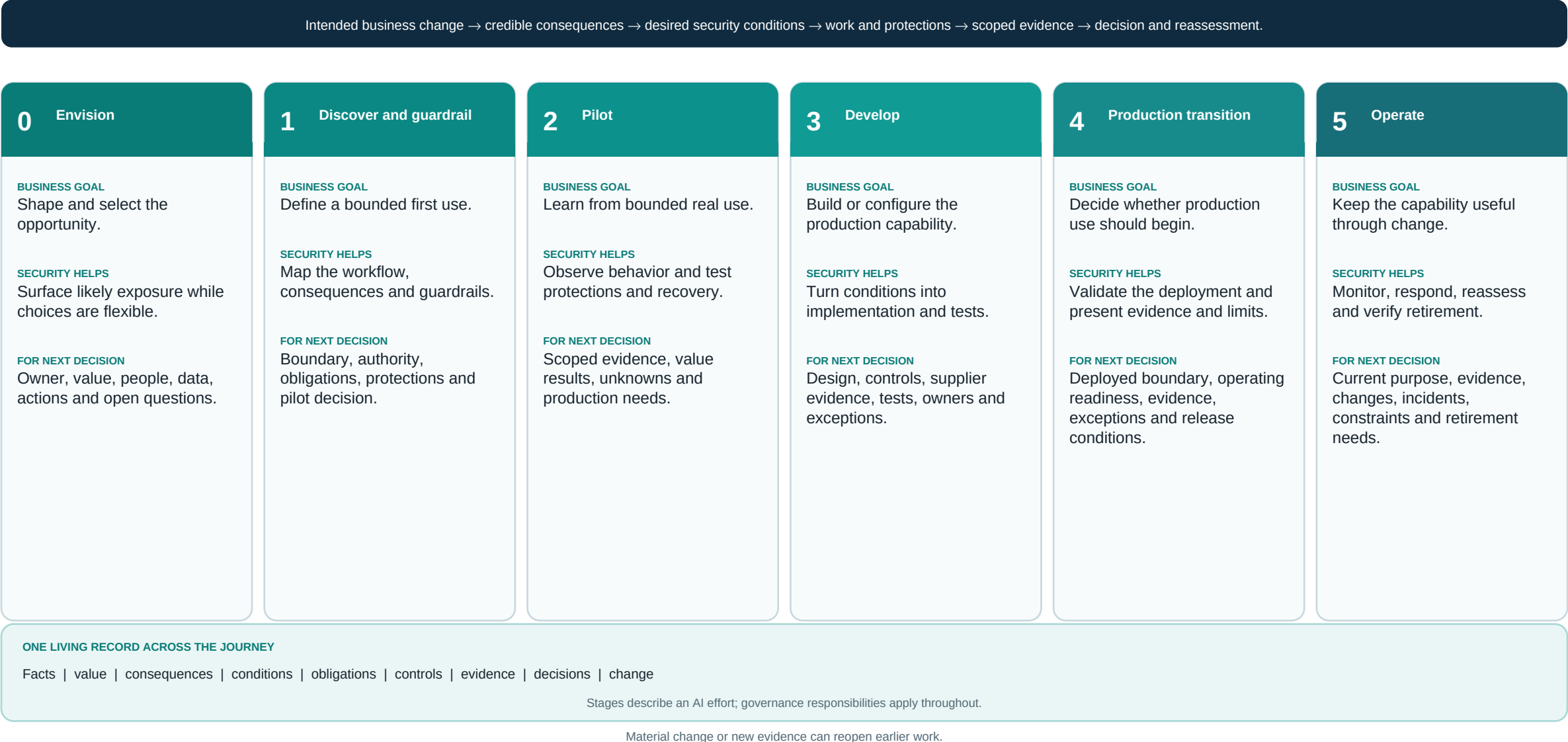


Applying Secure Business AI

How security supports business-led AI development and transformation



Start with the decision, then scale the work

One common approach fits built, bought, embedded and already-operating AI. Depth follows exposure and uncertainty.

1 NAME THE BUSINESS DECISION

- State the intended business change and how value will be judged.
- Name the people who decide the questions within their assigned authority.
- Separate business value evidence from security outcome evidence.

2 BUILD THE SHARED PICTURE

- Trace people, workflow, data, models, tools, suppliers, permissions, human effects and consequences.
- Record binding obligations only with their source, scope, decision owner and consequence.
- Treat current-stage entry as a starting point for intake, never as acceptance of earlier work.

3 DEFINE AND TEST CONDITIONS

- Choose proportional security conditions, protections and evidence.
- Security advises on the use, operates its assigned protections and exercises delegated authority.
- Reuse shared foundations and inherited evidence only within their tested scope.

4 DECIDE AND KEEP CURRENT

- Give each assigned owner the evidence, limits, uncertainty, exceptions and dissent relevant to their decision.
- Record each applicable item as Understood, Evidenced, Open, or Not applicable with a reason.
- Hold affected consequential actions or reduce autonomy through named authority when change invalidates evidence.

SHARED FOUNDATIONS: Reuse existing identity, data protection, logging, supplier assurance, secure delivery, incident response and governance processes by linking them into the living record. One person may hold several roles, and existing processes should carry the work when suitable. Each effort still confirms fit and local operation.

Envision

Shape a worthwhile AI opportunity and choose what deserves further work.

DECISION

The business owner chooses whether to explore, reshape, defer, or stop the idea. Data, privacy, legal, safety, security and other owners decide questions assigned to them.

WHAT MUST BE UNDERSTOOD

- The intended change and how value will be judged.
- Who uses the AI, who is affected, and where it may arrive or run.
- Likely data, supplier or platform, and whether output can cause a consequence before review.
- Early legal, contractual, policy, safety, or rights signals and the owner who can interpret them.

SECURITY SUPPORT AND DELIVERABLES

- Give short security input to opportunity shaping and prioritization.
- Identify the first specialists and decision owners needed.
- Record a preliminary data and action view, open questions, and the next bounded step.
- Operate any early protection assigned to security and route authority questions to their owners.

CANDIDATE DELIVERABLES

Security input to prioritization | Selected-use-case handoff | Preliminary data and action view | Open-question list with receiving owners

SECURITY OUTCOMES

- Material exposure is visible while choices are still flexible.
- Known facts are separated from assumptions.
- Urgent harm is routed to the person with authority to act.

EVIDENCE

A short use-case note records the owner, intended value, assumptions, sources, unresolved questions and next decision.

CHECKLIST

- Is the intended business change specific enough to examine?
- Are the business owner, likely users, affected people, data and actions named?
- Could AI output cause a material consequence before useful human review?
- Are obligation signals sourced and routed to the right decision owner?

ILLUSTRATIVE EXAMPLE | INVENTED, NOT TEST EVIDENCE

Customer service proposes an assistant that drafts account-credit recommendations. The service leader owns the idea and value case. Security flags customer data, staff reliance and future transaction authority as questions. No action authority is assumed.

Discover and guardrail

Build a shared factual picture and define a safe, bounded first use.

DECISION

Assigned business, data, privacy, legal, delegated security, exception and other owners decide whether the bounded pilot proceeds, changes, pauses or stops within their authority. If their decisions conflict, named authority holds the affected activity inside its existing approved boundary until the conflict is resolved and recorded.

WHAT MUST BE UNDERSTOOD

- The full workflow, system boundary, users, identities, integrations, providers and affected people.
- Source and derived data, including prompts, outputs, logs, memory, caches, training or evaluation stores, retention and deletion.
- Effective authority: what the AI, tools and people can see or change, and where permissions are enforced.
- Credible failure and misuse scenarios, dependencies, and applicable obligations with source, scope and decision authority.

SECURITY SUPPORT AND DELIVERABLES

- Facilitate workflow, data, trust-boundary and consequence mapping.
- Help business, technology, privacy, legal and supplier owners choose proportional guardrails.
- Test required protections before data access or action, and define pilot observations, stop routes and evidence.
- For bought or embedded AI, establish platform fit before pilot commitment.

CANDIDATE DELIVERABLES

Living use-case profile | Initial threat and risk picture | Pilot boundary and guardrails | Decision-rights map | Protection evidence and pilot decision

SECURITY OUTCOMES

- The pilot boundary limits access, action, reach and duration.
- Permissions are enforced outside the model, including when hostile content or prompt injection reaches it.
- Human review is useful because reviewers have time, skill, context and power to reject.
- If a provider cannot expose or enforce a needed control, the use case, permitted data or available actions are restricted and the limitation is recorded.

EVIDENCE

The living profile, boundary diagram, guardrail tests, obligation sources and recorded business decision show exactly what the pilot may do.

CHECKLIST

- Can the team trace data through prompts, outputs, logs, memory and derived stores through deletion?
- Are identities, integrations and effective permissions clear and enforced outside the model?
- Are credible misuse, prompt-injection, leakage, reliance and availability scenarios addressed?
- Can a capable human review and reject consequential output before it takes effect?
- Does the pilot have a named owner, time limit, stop route and evidence plan?

ILLUSTRATIVE EXAMPLE | INVENTED, NOT TEST EVIDENCE

The pilot is draft-only. It uses de-identified cases in a restricted workspace, cannot call the finance API, and produces a draft for a trained service supervisor who may reject it. Logs exclude unnecessary customer content and have a tested deletion period.

Pilot

Learn whether the bounded use is valuable and what broader use would require.

DECISION

Assigned owners decide whether to develop, pivot, extend within a revised boundary or stop. Data and privacy owners decide any extension to live data, and exception owners decide requested departures within their authority.

WHAT MUST BE UNDERSTOOD

- The data that actually appears and where it moves or persists.
- How users rely on output and whether human review works under real time and workload pressure.
- What the model, tools and provider actually reach or do, including unexpected behavior.
- Control performance, events and near misses, stop and recovery behavior, and remaining value and security unknowns.

SECURITY SUPPORT AND DELIVERABLES

- Test access, data, action, monitoring, response and recovery within the pilot.
- Observe user behavior and exercise the stop route.
- Update scenarios, effective authority, production needs and the evidence record.

CANDIDATE DELIVERABLES

Pilot plan and boundary | Test and observation results |
Event and near-miss record | Exercised stop route |
Updated profile, production needs and pilot decision

SECURITY OUTCOMES

- The bounded controls work in observed use, with limits stated.
- The team can detect, contain and learn from unwanted behavior.
- Evidence distinguishes what was tested from what remains unknown.

EVIDENCE

Observed results, event records, exercise evidence and a decision record state what the pilot showed and what it did not show.

CHECKLIST

- Did actual data, user behavior or provider behavior differ from the plan?
- Did human review catch weak or unsafe drafts without becoming a rubber stamp?
- Were access, prompt-injection resistance, monitoring, stop and recovery tested?
- Are value results, security evidence, unknowns and scope limits presented separately?
- Is retained pilot data accounted for and disposed of if the pilot ends?

ILLUSTRATIVE EXAMPLE | INVENTED, NOT TEST EVIDENCE

Supervisors review every draft recommendation made from de-identified cases. The team measures useful drafts separately from rejected or corrected drafts, tests hostile case text, exercises immediate pilot shutdown, and records where logs and model-provider evidence remain incomplete. Any move to live cases is a recorded boundary extension under the data and privacy owners' conditions.

Develop

Build, buy or configure the production capability and prepare it for validation.

DECISION

Product and business owners decide whether to seek production validation. Delegated security and other specialist owners decide their assigned questions, and exception owners resolve departures within their authority.

WHAT MUST BE UNDERSTOOD

- The target workflow, environments, models, data, identities, integrations, tools and suppliers.
- Every deterministic and probabilistic step, action boundary, failure path and operating owner.
- Which shared controls and supplier evidence are inherited, their tested scope, and what needs local validation.
- For bought or embedded AI: configuration, integration, contract, data use, change notice, support and exit conditions.

SECURITY SUPPORT AND DELIVERABLES

- Check platform fit before commercial or technical commitment, then help turn outcomes and obligations into traceable implementation items.
- Support secure patterns, architecture, configuration, integration and supplier evidence review.
- Test misuse, access, action, resilience, recovery and change behavior; record unresolved limits and exceptions.

CANDIDATE DELIVERABLES

Target outcomes and control set | Architecture and data flows | Traceable implementation items | Validation plan and results | Supplier evidence, operating-model draft and exception records

SECURITY OUTCOMES

- Production protections trace to desired security conditions and sourced obligations.
- Access and exact action permissions are enforced by systems around the model.
- Failure handling, monitoring, recovery and human intervention are built for the real workflow.
- Recovery authority is named, and retry handling prevents or reconciles duplicate effects.

EVIDENCE

Architecture, test results, supplier evidence, exceptions and an operating draft show the implemented state and remaining limits.

CHECKLIST

- Was platform fit checked before commercial or technical commitment, and does every material condition trace to an implementation item, owner and test?
- Are model permissions limited by authenticated tools and deterministic policy checks?
- Does approval bind the exact action, target and parameters, with reapproval when they change?
- Are data retention, deletion, logging, monitoring, failure and recovery implemented end to end?
- Is inherited or supplier evidence current, scoped and supplemented by local tests?

ILLUSTRATIVE EXAMPLE | INVENTED, NOT TEST EVIDENCE

The production design adds a credit API tool limited to exact approved credit types, amounts and customer accounts. Policy code and a task-specific service identity enforce the limit. Supervisor approval binds the approving identity, target account, credit type and amount; changed parameters require new approval, and delegated authority cannot expand itself. The team tests interruption and retry behavior and names who may authorize recovery.

Production transition

Decide whether the deployed capability can begin its intended production use.

DECISION

Named release, business, data, privacy, legal, delegated security, recovery and exception owners release, narrow, defer or stop within their authority. Conflicts hold the affected activity under named authority.

WHAT MUST BE UNDERSTOOD

- The deployed population, data, models, integrations, identities, permissions and autonomy.
- Differences between the tested build and production configuration.
- Residual exposure, exceptions, operating readiness and named release and stop authority.
- What signals or changes require review, constraint, rollback or a return to an earlier stage.

SECURITY SUPPORT AND DELIVERABLES

- Validate access, exact actions, refusal, containment, monitoring, escalation and recovery in production conditions.
- Reconcile approved, tested and deployed states.
- Present evidence, limits and open exceptions to the release owner and record the decision.

CANDIDATE DELIVERABLES

Production configuration record | Validation and exercise evidence | Transition record | Operating owners and response routes | Exceptions, release decision and reassessment triggers

SECURITY OUTCOMES

- The deployed boundary meets the agreed security conditions within stated evidence limits.
- Operators can detect, contain, investigate and recover.
- The decision owner sees residual exposure, dissent, exceptions and reassessment triggers.

EVIDENCE

Production tests, exercises, configuration records and the recorded release decision define the allowed use and conditions.

CHECKLIST

- Does the deployed system match the tested boundary, including identities, data and tool permissions?
- Can records distinguish proposed, authorized, attempted, blocked and confirmed actions?
- Does the destination system confirm the completed action independently of an AI or agent success message?
- Have containment, escalation, rollback and recovery routes been exercised with operators?
- Does recovery reconcile the destination record so interruption or retry cannot duplicate an effect?
- Are exceptions, evidence limits, dissent, binding obligations and change triggers visible to the release owner?

ILLUSTRATIVE EXAMPLE | INVENTED, NOT TEST EVIDENCE

The release owners review a production test showing that only supervisor-approved credits reach the credit API. Attempts to exceed the amount limit, change an approved parameter or bypass review are blocked and logged. The customer account record, rather than the assistant's success message, confirms completion, and recovery reconciliation prevents duplicate credits.

Operate

Keep the AI useful and trustworthy as the business, technology and exposure change.

DECISION

Assigned owners continue, constrain, change, expand, stop, resume or retire within their authority. When material change invalidates evidence, named authority holds affected consequential actions or reduces autonomy until renewed evidence supports a recorded resumption decision.

WHAT MUST BE UNDERSTOOD

- Current purpose, users, affected people, owners, data, models, tools, suppliers, integrations and effective authority.
- Changes in reliance, volume, behavior, provider terms, control health and business value.
- Signals, incidents, drift, exceptions, unresolved evidence and recovery readiness.
- Data, access, contracts, records, dependencies and obligations that must be handled at retirement.

SECURITY SUPPORT AND DELIVERABLES

- Maintain monitoring, response, exercises and the current system record.
- Assess material changes and retest affected outcomes; use named authority when constraint or stop is needed.
- Record the interim constraint, renewed evidence and authority for resumption.
- Support periodic continuation, expansion and retirement decisions and verify decommissioning.

CANDIDATE DELIVERABLES

Current profile and operating record | Monitoring, incident and exercise evidence | Change assessments and retest results | Continuation or constraint decisions | Retirement and decommissioning evidence

SECURITY OUTCOMES

- Material change triggers proportionate reassessment and affected controls are retested.
- Incidents and control weakness reach named decision owners quickly.
- Retirement revokes unneeded authority and access, closes dependencies, and handles retained data under sourced duties with evidence.

EVIDENCE

Current records, monitoring, incidents, change reviews, retests and retirement receipts support each operating decision.

CHECKLIST

- Are purpose, owners, data, authority and dependencies still accurate?
- Do monitoring and incident routes show whether controls and human review remain effective?
- Did model, data, tool, supplier, user, volume or business-purpose change reopen earlier work?
- Are expansion and exceptions decided by named owners with current evidence?
- If retiring, are access, tools, data, logs, contracts and downstream dependencies closed?

ILLUSTRATIVE EXAMPLE | INVENTED, NOT TEST EVIDENCE

The team monitors approved and blocked credits, reviewer overrides, unusual case text and supplier changes. A new model or higher credit limit triggers targeted reassessment and temporarily removes autonomous credit execution under named authority. Renewed evidence and a recorded decision are required before resumption. Retirement revokes the service identity, disables the tool and handles records under sourced retention duties.

Follow every concern across the stages

The map tests coverage. Each effort applies only the depth justified by its exposure, uncertainty and decision.

CONCERN	0 Envision	1 Discover and guardrail	2 Pilot	3 Develop	4 Production transition	5 Operate
Business purpose and value	Intent and owner	Success measures	Observed value	Target workflow	Release conditions	Value and purpose drift
People and decisions	Users and affected people	Rights and review design	Review behavior	Decision and operating roles	Release and stop authority	Current owners and impacts
Human effects	Likely affected people	Privacy, legal, safety, fairness and workforce questions	Actual reliance and effects	Human review and recourse design	Production effect and review tests	Reliance, recourse and effect changes
Data and lifecycle	Likely data	Flows, logs, memory, derived stores, deletion	Actual data and retention	Production handling	Deployed handling	Change and retirement
Identity, access and action	Likely consequence	Effective authority and pilot limits	Actual reach and behavior	Exact permissions outside model	Production permission tests	Drift, constraint and revocation
Threat and misuse	Early concerns	Credible scenarios and guardrails	Hostile-content tests	Misuse and resilience tests	Containment exercises	Signals, incidents and retest
Technology and suppliers	Arrival path	Boundary, providers and dependencies	Observed provider behavior	Build, configure, integrate and contract	Deployed reconciliation	Supplier and model change
Evidence and obligations	Signals and sources	Binding source and authority	Scoped pilot evidence	Traceability and exceptions	Decision evidence and limits	Current evidence and reassessment
Response, recovery and retirement	Urgent routing	Stop and evidence plan	Stop route exercised	Failure and recovery built	Production exercise	Response and decommissioning

What this package establishes

This guide presents a proposed neutral application companion for review. Its labels preserve the authority of the canonical sources.

SOURCE AND STATUS

- The canonical public sources are Secure Business AI and the AI Governance companion. This guide contains no organization-specific assignments or internal decision identifiers.
- This is a proposed neutral application companion and review draft.
- Model-assisted external review informed the eight bounded High corrections incorporated in this adaptation; the rendered preview still requires review.
- Completion, review or publication does not establish control effectiveness, compliance, suitability, business value or acceptance for a particular use.

WHAT REMAINS TO BE TESTED

- Owner content acceptance and practitioner review of the public adaptation.
- Reader testing across built, bought, embedded, employee-used, agentic and already-operating AI.
- Field use and evidence that the framework supports decisions without unnecessary document work.
- The existing architecture review's 30 findings, which this companion does not close or reclassify.

INTERPRETATION

- The stages describe security's contribution to an effort's delivery journey. They apply the Secure Business AI architecture and AI Governance companion, but do not replace governance responsibilities or form a maturity scale.
- Business owners decide value and use. Data, privacy, legal, safety, delegated security, exception, release, recovery and other owners decide assigned questions within their authority. One person may hold several roles, and existing processes should carry the work when suitable.
- Security advises on business use, operates protections assigned to security and exercises delegated authority. Conflicting decisions hold the affected activity within its existing approved boundary through named authority until resolved and recorded.
- An effort may enter at its current stage, but entry does not accept earlier decisions or evidence. Unmanaged use first receives intake and containment to establish exposure, preserve evidence, restrict urgent harm and name the next decision owners.
- A provider that cannot expose or enforce a needed control causes the team to record the limitation and restrict the use case, permitted data or available actions.
- Material change invalidates only affected evidence. Named authority holds affected consequential actions or reduces autonomy until renewed evidence supports a recorded resumption decision.